

Endpoint Protection

Community Home

Threads 301K

Library 12.7K

Blogs 0

Events 0

Members 6.2K

[← BACK TO LIBRARY](#)

Honeytokens: The Other Honeypot

Recommend



Migration
User

by Lance Spitzner

Jul 17, 2003 02:00 AM

Statistics
0 Favorited
0 Views
0 Files
0 Shares
0 Downloads

Authors Note: This paper was originally released on 17 July, 2003. In the days following its release, I received more feedback on this paper than on all other pr

The purpose of this series of honeypot papers is to cover the breadth of honeypot technologies, values and issues. I hope by now readers are beginning to un
honeytokens. Honeytokens are everything a honeypot is, except they are not a computer.

Definition

One of the greatest misconceptions of honeypots is they have to be a computer, some physical resource for the attacker to interact with. While this is the trad

Note in the definition that we do not state a honeypot has to be a computer, merely that its a resource that you want the bad guys to interact with. That is exa sizes, however they all share the same concept: a digital or information system resource whose value lies in the unauthorized use of that resource. Just as a hc beyond just physical computers.

The concept of honeypots are not new. This concept is as old as security itself. For example, I've read discussions of map-making companies inserting bogus data to catch hackers. What makes honeypots new and exciting is we now have a single term to bring these concepts together for the information security community.

The term *honeypot* was first coined by Augusto Paes de Barros in 2003 on the honeypots mailing list. This term aptly described the concept, and as is often

How They Work

A honeypot is just like a honeypot, you put it out there and no one should interact with it. Any interaction with a honeypot most likely represents unauthorized people have access to patient data (such as doctors, nurses, etc). If a hospital fails to protect patient data, that hospital (and the individuals involved) is responsible for unauthorized access to a database when that database has thousands, if not millions of records, with hundreds of authorized users? Maintaining who is authorized is the responsibility of the hospital, not the patient.

A bogus medical record called "John F. Kennedy" is created and loaded into the database. This medical record has no true value because there is no real patient privacy. It is as simple as that, no fancy algorithms, no signatures to update, no rules to configure. You load the records, monitor it, and if someone acce

Another example is bogus Social Security or credit card numbers. We have read numerous stories of large databases compromised, with thousands of SSNs or bogus numbers embedded in a database. If the numbers are accessed, you know someone is violating system security. A university could put SSN honeypots into a vendors on-line ecommerce site. These honeypots would be unique numbers, so attackers would not know what was the honeypot and what were likely been compromised.

For example, the credit card number 4356974837584710 could be embedded into database, file server, or some other type of repository. The number is unique

```
alert ip any any -> any any (msg:"Honeytoken Access - Potential Unauthorized Activity"; content:"4356974837584710");
```

This concept can easily be extended beyond databases. File, web, or email servers can all have honeytokens embedded into them. Anything that has data can have honeytokens embedded into it. Detection Systems can then have signatures customized to look for these honeytokens. If you see any honeytokens traversing your networks, you know you have been compromised. You can detect this unauthorized activity and generate an alert (the HoneyNet Project has such concepts currently under development).

Value

Just like traditional honeypots, honeytokens do not solve a specific problem. They are not designed specifically to detect blackhats or prevent attacks. Instead, they potentially have a problem. I see honeytokens used primarily for the insider threat, for the trusted individuals on the inside. You leverage the fact that the insider has real value is when they are combined with other solutions. For example, in many cases honeytokens may not prove unauthorized activity. Instead, they may mean that when an employee attempts to copy and transfer the file, you have identified a problem. Either you have a confused employee looking where they shouldn't, or you

In my mind, what exponentially increases honeytokens value is the cost involved, which is minimal. Think about it, there is no technology to deploy, no vendors tools.

Finally, honeytokens have extensive flexibility. You are limited only by your imagination. As we have demonstrated in the section above, honeytokens excel as eavesdroppers. Honeytokens can be used to smoke them out and identify who they are. How you do that is simply a matter of how creative you want to get. For example, you could plant a honeytoken in management's email. The email could look like this:

To: Chief Financial Officer From: Security help desk Subject: Access to financial database Sir, The security team has updated your access to the c

If an attacker is cruising through emails and comes across this, they most likely will attempt to access the financial server thinking they can retrieve highly confidential information. If someone connects to the honeypot and uses one of your honeypot logins, you know you have someone reading senior management's email. The moment someone connects to the honeypot, you know exactly whose email has been compromised. In addition, within the honeypot you can place different bogus records (additional honeypot tokens). These can be filled with sensitive information to determine the attacker's motivation. What was even more clever, Cliff took it a step farther by putting a mailing address in the documents. The attacker was left with the need to build a "call home" functionality into the honeypot when the attacker does it for you? The options are almost unlimited on how this technology can be used.

Conclusion

Honeytokens are an exciting new dimension for honeypots, especially for the insider threat. They are cost effective, simple to deploy, and highly effective. Honeytokens are not a silver bullet, but they are a powerful tool in your arsenal. Don't wait until you're breached to start using them. Start today. Deploy your honeytokens in one place, then let the attackers come to you.

Related Articles

View more articles by Lance Spitzner on SecurityFocus.

This article originally appeared on SecurityFocus.com -- reproduction in whole or in part is not allowed without expressed written consent.

Tags and Keywords

Comments

Migration User

Mar 01, 2012 10:55 PM



Hi,

Honeytoken is a very neat concept. Is there out-of-box support for honeytoken in Symantec's DLP (Vontu)? If yes, perhaps can share the URL of website where we can get more info?

Thanks in advance.

Simon

Related Entries and Links

No Related Resource entered.

[PRODUCTS](#)[APPLICATIONS](#)[SUPPORT](#)[COMPANY](#)[HOW TO BUY](#)

Copyright © 2005-2026 Broadcom. All Rights Reserved. The term "Broadcom" refers to Broadcom Inc. and/or its subsidiaries.

Hosted by Higher Logic, LLC on the behalf of Broadcom - [Privacy Policy](#) | [Cookie Policy](#) | [Supply Chain Transparency](#)

[Terms of Use](#)